Agent Wallet

Security Self Assessment

Topic F

2026 FinTechathon

2026 Shenzhen International FinTech Competition (FinTechathon)
Xilihu FinTech College Students Challenge

Date	**:**	**15/10/2026**
Version	**:**	**1.0**
Status	**:**	**Completed**

Contents

Introduction....3
1 System scope and security boundaries....3
2 Permission tier implementation....4
Controls before submission....4
Stop and recovery behavior....4
3 Known risk list....5
R01 Incorrect AI decisions....5
R02 Prompt injection and over permissioning....5
R03 Backend or local identity compromise....5
R04 Unsafe targets and token allowances....5
R05 Simulation and market assumptions....5
R06 Stale approvals and duplicate execution....6
R07 Unknown submissions and availability....6
R08 Sensitive data exposure and retention....6
R09 Audit tampering and mismatched state....6
R10 Wrong chain or false RPC identity....6
Evidence and review status....7

Introduction

This document explains what the AI agent is allowed to do, how the application controls financial actions, and which risks remain. It gives developers and reviewers a practical basis for checking the security design and deciding whether the local demonstration is ready to present.

The assessment covers the current educational prototype. Its controls bound AI authority, but depend on a trusted local host and do not establish production security.

1 System scope and security boundaries

The stack contains a React UI, owner authenticated FastAPI backend, PostgreSQL and Anvil chain 31337. Ollama is the local AI provider; OpenAI is optional. A fresh smart account holds 500 TestUSDC and 500 TestWETH at a fixed mock 1:1 price.

Boundary	Responsibility
AI	Read the supplied snapshot and policy; recommend HOLD, SWAP or a policy draft. No signer, owner token, arbitrary tools or permission changes.
Application	Validate typed data, enforce approved policy, simulate, assess risk, obtain approval when required and coordinate execution/audit.
Smart account	Independently enforce agent authorization, pause/revoke, daily limit, allowed targets/assets, minimum output and replay protection.

Only local fake assets are supported. There is no AML, sanctions, KYC, fraud intelligence or suitability screening; policy checks do not provide regulatory clearance. The contracts are educational and unaudited.

2 Permission tier implementation

Permission is determined by trusted code. A model response never authorizes execution. Reversible application controls are distinguished from irreversible submitted transactions.

Tier	Implementation and authority
Read only	The agent observes supplied balances and policy. Owner authenticated API reads expose activity, approvals and audit to the UI.
Prepare and recommend	The model returns a validated draft or typed HOLD/SWAP. Trusted code supplies executable addresses and chain. AI amounts are preserved for independent evaluation.
Reversible controls	Owner can stop schedules, reject pending proposals and freeze execution. Resume is owner only and leaves scheduling off. Submitted transactions cannot be undone.
Explicit approval	Owner activates each immutable policy version and separately enables its schedule. MEDIUM proposals require exact owner review, digest/version binding and ten minute expiry.
Automatic execution	LOW risk and policy permitted swaps may execute after fresh checks. The execution adapter submits only the validated stored operation.
Always block or escalate	Invalid output/approval, policy failure, failed simulation, HIGH risk, wrong chain or stale authorization are denied. Unknown sends require investigation and reconciliation.

Controls before submission

Daily spending is capped at 100 TestUSDC equivalent in the supported application; policy may be stricter. Both directions consume the mock allowance. Per trade ceilings, allowlists, destination, operation, cadence and slippage are checked independently. Simulated allocation must improve the target and satisfy any hard minimum.

One proposal consuming at least 70% of the approved daily limit is MEDIUM unless a HIGH finding dominates. A valid approval cannot override other denials. The coordinator locks/reserves the wallet, rechecks state and simulation, and records durable intent before RPC submission.

Stop and recovery behavior

Exhausted budget, cadence or allocation ineligibility skips AI. Three consecutive scheduled failures/blocked checks freeze execution; repeated HOLD only creates an advisory. Freeze persists local denial and requests contract pause. Unknown sends retain the reservation and are never blindly resent.

Policy and risk routing apps/api/app/execution/pipeline.py

Approval and execution rechecks apps/api/app/execution/coordinator.py

3 Known risk list

Likelihood and impact are qualitative engineering judgments for this local prototype, not measured probabilities. Evidence links identify inspectable code/tests, not a claim that each test was rerun today.

R01 Incorrect AI decisions

Trigger: Model misreads allocation or amount. Likelihood: High. Impact: Poor fake asset allocation.

Control: Typed output, owner review and deterministic safety gates. Detection: Rule results and proposed versus expected allocation.

Remaining risk: Small permitted trades or HOLD may delay the goal.

Evidence apps/api/tests/test_treasury_decisions.py

R02 Prompt injection and over permissioning

Trigger: Goal or copied text asks to override rules. Likelihood: Medium. Impact: Misleading draft or recommendation.

Control: No model signing/tools; trusted addresses; schema validation and explicit activation. Detection: Draft review, schema errors and blocked findings.

Remaining risk: Owner may approve a misleading draft; no exhaustive injection guarantee. No document ingestion exists.

Evidence apps/api/app/agent/portfolio.py

R03 Backend or local identity compromise

Trigger: Attacker controls backend, owner token or unlocked RPC. Likelihood: Medium. Impact: Unauthorized fake spend or policy changes.

Control: Owner authentication and independent contract limits/pause. Detection: Compare contract events, proposals and owner actions.

Remaining risk: Unlocked RPC can impersonate the owner; compromised backend bypasses off chain rules.

Evidence contracts/test/PolicySmartAccount.t.sol

R04 Unsafe targets and token allowances

Trigger: Harmful target is approved or withdrawal allowance abused. Likelihood: Low in fixed mocks. Impact: Fake token loss.

Control: Target/assets allowlists; exact temporary allowances; output balance check; direct approval proposals denied. Detection: Simulation, risk findings and chain events.

Remaining risk: Owner whitelist choice is trusted and contracts are unaudited.

Evidence contracts/src/PolicySmartAccount.sol

R05 Simulation and market assumptions

Trigger: Modeled output differs from execution or prices change. Likelihood: Medium for extensions. Impact: Incorrect safety decision.

Control: RPC call/gas simulation, revalidation, integer checks and minimum output. Detection: Reverts, failed receipts and observed deltas.

Remaining risk: Expected deltas assume 1:1 mocks; no real oracle, liquidity or MEV modeling.

Evidence apps/api/app/simulation/engine.py

R06 Stale approvals and duplicate execution

Trigger: Proposal/policy changes or concurrent work repeats. Likelihood: Low with controls. Impact: Unauthorized or duplicate spend.

Control: Digest/version/expiry checks, wallet locks, unique execution and on chain replay ID. Detection: Approval conflicts, busy state and replay reverts.

Remaining risk: Database/backend compromise can defeat off chain checks.

Evidence apps/api/tests/test_api.py

R07 Unknown submissions and availability

Trigger: RPC/model failure or crash leaves unclear work. Likelihood: Medium. Impact: Duplicate retry or blocked progress.

Control: Durable reservations, no blind resend, failure freeze and explicit recovery. Detection: UNCERTAIN state, failure counter and receipt/event investigation.

Remaining risk: Manual recovery may be needed; pause RPC can fail and submitted transactions cannot be cancelled.

Evidence apps/api/tests/test_automation.py

R08 Sensitive data exposure and retention

Trigger: Secrets enter goals, exports or hosted model calls. Likelihood: Medium. Impact: Information disclosure.

Control: Environment secrets, memory only UI token, sanitized errors and limited payload. Detection: Disclosure tests and manual export review.

Remaining risk: No generic text redaction, encryption or retention/deletion automation. Hosted data leaves the local boundary.

Evidence apps/api/tests/test_boundaries.py

R09 Audit tampering and mismatched state

Trigger: Administrator changes records or DB survives a chain reset. Likelihood: Medium. Impact: Unreliable evidence or recovery.

Control: Append only application history, receipt hashes and matching deployment guidance. Detection: Compare chain events, deployment and DB records.

Remaining risk: Administrators can alter data; no cryptographic audit seal or full deployment attestation.

Evidence apps/api/app/models/entities.py

R10 Wrong chain or false RPC identity

Trigger: Endpoint reports unexpected or misleading identity. Likelihood: Low under trusted host assumption. Impact: Execution outside sandbox assumptions.

Control: Only local/31337, local HTTP hostname restrictions, Anvil client and constructor checks. Detection: Startup rejection and RPC identity tests.

Remaining risk: Malicious RPC can lie; chain/client strings are not cryptographic proof.

Evidence apps/api/app/config/settings.py

Evidence and review status

The 14 October cleanup recorded 237 Python passes, six optional integrations skipped and four separately passing Anvil suites. Earlier browser and Solidity evidence is dated separately. No application tests were rerun for this report.

Dated verification and limitations docs/history/README.md